AUDIT REPORT · AUD-2026-IAM-01

Strong authentication and privileged access — KRL-ADM

Banque du Menhir (fictive) · Trésorerie

Lead auditor: **A. Auditeur** Owner: **DSI — équipe IAM** Date: **2026-11-02 23:20**

Run: **05-menhir-tresorerie-generiques**

1. Executive summary

OPINION AT TESTING

Needs improvement

7 controls tested	**2** findings	**0** findings closed and verified	**2** open findings
0 human approvals	**28** personal data items masked in evidence	**0 min 20 s** audit duration	**$0.439 *** measured AI cost



Critical: 0 High: 2 Medium: 0 Low: 0

Key messages

- 2 findings across 7 controls: 2 high.
- 2 findings remain open, with an action plan, an owner and a due date.

2. Scope and method

Engagement	AUD-2026-IAM-01
Entity	Banque du Menhir (fictive)
System	Trésorerie
System criticality	Supporte des fonctions critiques ou importantes (DORA)
Environment	Pré-production de démonstration
Owner	DSI — équipe IAM
Lead auditor	A. Auditeur
Date	2026-11-02 23:20
Framework	DORA art. 9(4) · RTS (UE) 2024/1774 art. 12, 21 · PSI-4
Work programme	existing catalogue reused · controls/AUD-2026-IAM-01.en.json

In scope

- Paramètres d'authentification et de session de la console KRL-ADM
- Comptes disposant d'un accès à la console
- Journalisation des actions d'administration

Out of scope

- Efficacité intrinsèque des facteurs MFA (robustesse des moyens d'authentification)
- Annuaire central et fédération d'identité
- Contrôles physiques

Method

1. Controls are derived from the framework (DORA, RTS 2024/1774, internal policy); severity is the one set by the policy.
2. Each test is a stored Python script, statically checked before execution (read-only) and run with a read-only service account.
3. The verdict comes from the script, never from the model. A screenshot is reviewed by Muse Spark to corroborate; on disagreement the control is flagged for review.
4. SAM 3.1 delineates the proving rows and the personal data, which is masked before distribution.
5. Every fix goes through a change request approved by the system owner, applied with a dedicated account, logged, then verified by the same test (DORA 9(4)(e)).
6. Every event and piece of evidence is sealed in a hash-chained audit trail (SHA-256).

Limitations

- Tests cover the configuration reported by the system, not the actual strength of authentication factors.
- AI-drafted scripts and catalogue must be reviewed by an auditor before being considered validated.
- Fictitious entity and data: demonstration.

3. Findings overview

REF.	RULE	TITLE	SEVERITY	TESTED	AFTER	STATUS	DUE DATE
F-01	PSI-4.6	Logging of administration actions	High	Non-compliant		Open	2027-01-31
F-02	PSI-4.7	No generic or shared admin accounts	High	Non-compliant		Open	2027-01-31
—	PSI-4.1	Mandatory MFA for privileged accounts	Critical	Compliant			
—	PSI-4.2	Mandatory MFA for users of critical system	High	Compliant			
—	PSI-4.3	Strong password policy	Medium	Compliant			
—	PSI-4.4	Account lockout after failed logins	Medium	Compliant			
—	PSI-4.5	Inactive session timeout	Medium	Compliant			

4. Detailed findings and controls

F-01 PSI-4.6 Logging of administration actions — High — Non-compliant — Open

CRITERIA

All administration actions are logged
PSI-4.6 · RTS 12(2)(c)(i)

CONDITION

Observed: `false`
Expected: `true`
admin_audit_log is false.

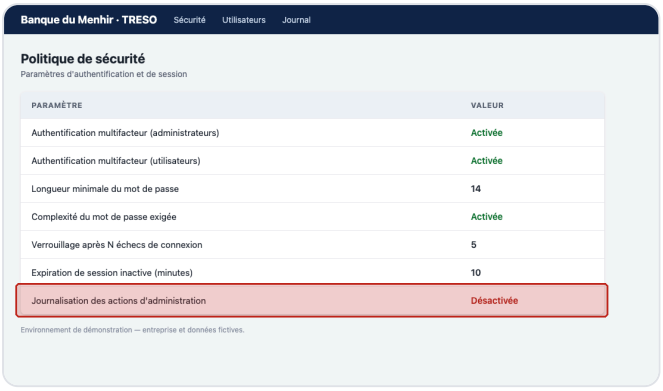
RISK

Without admin audit logging, privileged actions cannot be traced, preventing detection and investigation of abuse

RECOMMENDATION

Enable logging of all administration actions by setting admin_audit_log to true
Due date: 2027-01-31 · Owner: DSI — équipe IAM

Test procedure: Retrieve the security configuration via GET /api/security and verify that admin_audit_log is true



At testing — The screenshot corroborates the test. The security policy table shows administration action logging as disabled.
`2026-11-02 23:20:42 · SHA-256 3cb47ea26869943a…`

F-02 PSI-4.7 No generic or shared admin accounts

High · Non-compliant · Open

CRITERIA

No account with role admin is generic or shared and every admin has a nominative login of the form initiale.nom with a personal email
PSI-4.7 · DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)

CONDITION

Observed: `[{"login": "r.leroy", "email": "r•••@banque-menhir.example", "role": "admin"}, {"login": "admin", "email": "a•••@banque-menhir.example", "role": "admin"}, {"log…`
Expected: `for all users where role == admin: login matches initiale.nom pattern and email is personal, with no function login and no shared mailbox`
3 of 5 admin account(s) violate nominative login or personal email requirements.

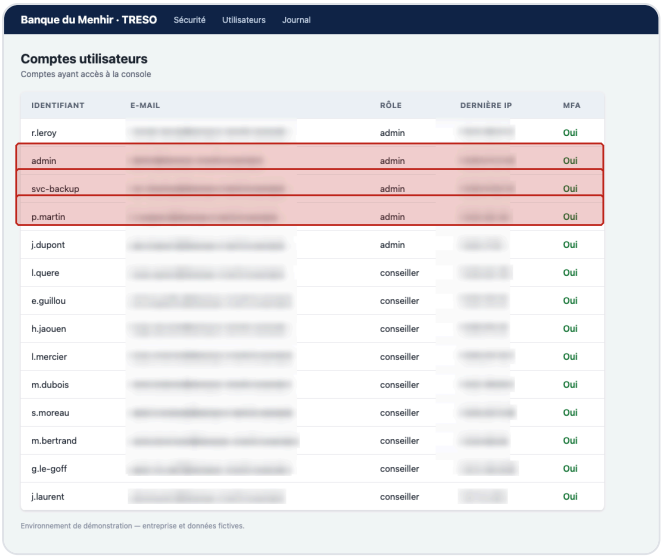
RISK

Generic or shared admin accounts destroy individual accountability and prevent attribution of privileged actions

RECOMMENDATION

Remove or disable generic and shared admin accounts and replace them with dedicated nominative accounts
Due date: 2027-01-31 · Owner: DSI — équipe IAM

Test procedure: Retrieve all accounts via GET /api/users and verify that every user with role admin has a nominative login and a personal email without function identifier or shared mailbox

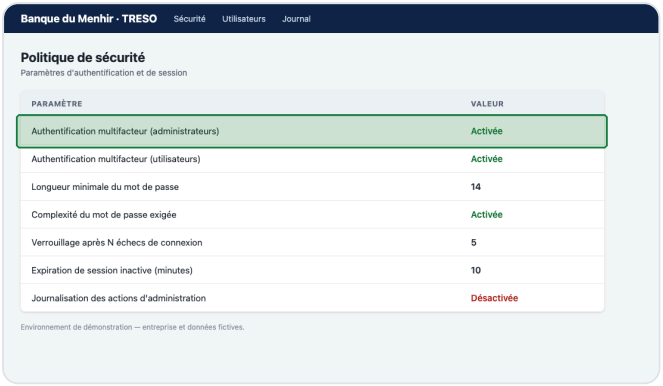


At testing — The screenshot corroborates the test. Screenshot shows three admin rows with generic logins or non-personal emails matching the automated finding. · 28/28 personal data items masked (26 spotted by the AI, the rest by the deterministic safety net)
`2026-11-02 23:20:51 · SHA-256 3955924be714a6dd…`

PSI-4.1 Mandatory MFA for privileged accounts

Critical · Compliant

Compliant control — MFA is enforced for all privileged admin accounts on KRL-ADM · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `true`

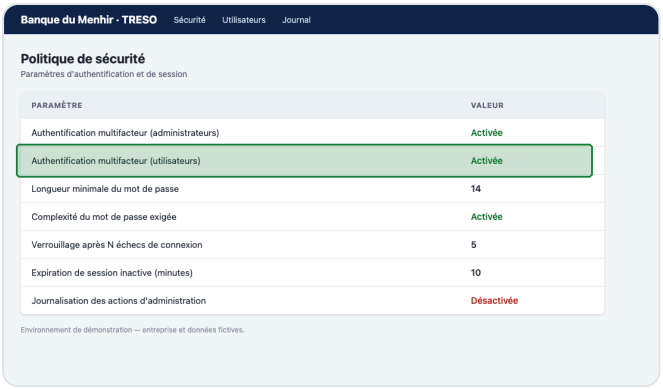


At testing — The screenshot corroborates the test. The security policy table shows administrator MFA as Activée.
`2026-11-02 23:20:39 · SHA-256 4a199e634e547c36…`

PSI-4.2 Mandatory MFA for users of critical system

High · Compliant

Compliant control — MFA is enforced for standard users because KRL-ADM supports critical or important functions · DORA 9(4)(d), RTS 21(1)(f)(ii)
Observed: `true`

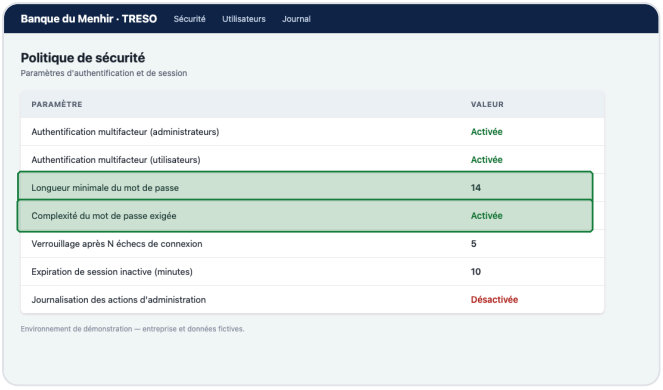


At testing — The screenshot corroborates the test. The security policy table shows user MFA as Activée, matching the automated pass result.
`2026-11-02 23:20:40 · SHA-256 37cb9b54c9f1d788…`

PSI-4.3 Strong password policy

Medium · Compliant

Compliant control — Passwords require a minimum length of 12 characters with complexity requirements enabled · DORA 9(4)(d)
Observed: `{"password_min_length": 14, "password_require_complexity": true}`

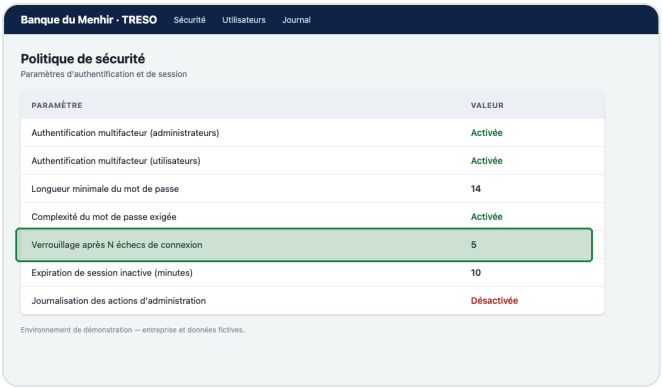


At testing — The screenshot corroborates the test. The screenshot shows minimum password length of 14 and password complexity enabled, matching the automated result.
`2026-11-02 23:20:40 · SHA-256 762094eac3ab6d39…`

PSI-4.4 Account lockout after failed logins

Medium · Compliant

Compliant control — Accounts lock after at most 5 failed login attempts and lockout is never disabled · DORA 9(4)(c)
Observed: `5`



At testing — The screenshot corroborates the test. The screenshot shows lockout after 5 failed logins, matching the automated test result.

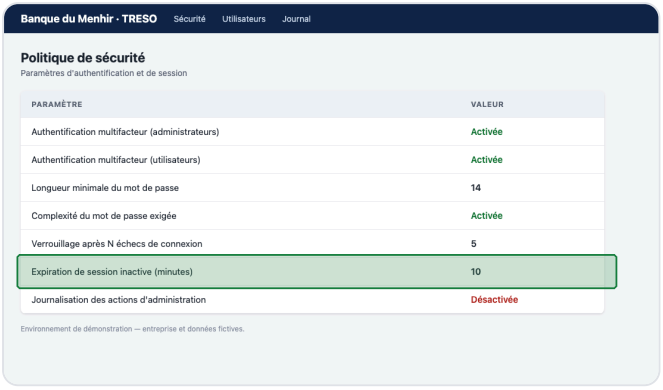
`2026-11-02 23:20:41 · SHA-256 cdab8ea903589a55…`

PSI-4.5 Inactive session timeout

Medium · Compliant

Compliant control — Inactive sessions expire after at most 15 minutes and expiration is never disabled · DORA 9(4)(c)

Observed: `10`



At testing — The screenshot corroborates the test. The security policy table shows inactive session expiration set to 10 minutes, matching the automated result.

`2026-11-02 23:20:41 · SHA-256 6a6df1458c08f70f…`

Appendices

A. Traceability matrix

REQUIREMENT	RULE	CONTROL	SCRIPT (SHA-256)	RESULT
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.1	C1 · Mandatory MFA for privileged accounts	098d37cd0158dd1a · script library (reused)	Compliant
DORA 9(4)(d), RTS 21(1)(f)(ii)	PSI-4.2	C2 · Mandatory MFA for users of critical system	fa35c17fbb1dfdd3 · script library (reused)	Compliant
DORA 9(4)(d)	PSI-4.3	C3 · Strong password policy	b440a5b4dc6b0fb3 · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.4	C4 · Account lockout after failed logins	10d2a8f06337b5bc · script library (reused)	Compliant
DORA 9(4)(c)	PSI-4.5	C5 · Inactive session timeout	4157e9750f010f98 · script library (reused)	Compliant
RTS 12(2)(c)(i)	PSI-4.6	C6 · Logging of administration actions	e2f3534909210977 · script library (reused)	Non-compliant
DORA 9(4)(c), RTS 21(1)(c), RTS 21(3)	PSI-4.7	C7 · No generic or shared admin accounts	5e917770866b8e47 · script library (reused)	Non-compliant

B. Evidence register

FILE			SHA-256
evidence/C1_before.png	C1 · At testing	2026-11-02 23:20:39	4a199e634e547c36f9d7d8a06d7e69d9670d53b6ec139be45cdd2621ffb2b2ee
evidence/C2_before.png	C2 · At testing	2026-11-02 23:20:40	37cb9b54c9f1d7888a02f90c3219a2e44b0ca2677709ed2415da10fc2662af2c
evidence/C3_before.png	C3 · At testing	2026-11-02 23:20:40	762094eac3ab6d39defee42329a5a9368eb5fa57fc8a5005c8b071fbfbf093ef
evidence/C4_before.png	C4 · At testing	2026-11-02 23:20:41	cdab8ea903589a556132856a0fcc932c647d3e62f070eafcc22255f7f4bc5f8c
evidence/C5_before.png	C5 · At testing	2026-11-02 23:20:41	6a6df1458c08f70f5027c0b7324a6ffe5c8b6aa82ebe239018881802088e87f9
evidence/C6_before.png	C6 · At testing	2026-11-02 23:20:42	3cb47ea26869943a2bd9ac1699e8746cc3755b0039104107b6c90a3331988afa
evidence/C7_before.png	C7 · At testing	2026-11-02 23:20:51	3955924be714a6dd76b0211820c1c1f503037c18cd038ef567dac7f388d59887

C. AI usage, costs and human oversight

MODEL	CALLS	INPUT TOKENS	OUTPUT TOKENS	IMAGES	COST (USD)

`muse-spark-1.3`	43	59,366	85,738	0	0.4386
`sam-3.1`	31	0	0	31	price not published
Total					**0.4386**

Personal data in evidence: 26/28 spotted by Muse Spark + SAM, 28/28 masked in the end thanks to the deterministic safety net (page text).

* sam-3.1: price not published (pricing.toml)

Safeguards

- Scripts: allow-listed imports, no write requests (static analysis before execution).
- Read-only test account: any write would be refused by the system (defence in depth).
- Fixes: allow-listed route and parameters, human approval, separate change account.
- Segregation of duties: the approver cannot be the auditor.

D. Integrity

Audit-trail fingerprint when the report was issued. Verify with `python -m attest verify <folder>`.

`2e4a473453d28e947257abadbce3f958104fc8a2bb640188ccedfddac0445df6`